

Threat Intelligence

FIG_000 · guide v1.0 · 2026 · open reference · 9 sections

by Swastik Sagar

The framework behind every "known-bad IP" and every correlation rule – IOCs vs IOAs, the Pyramid of Pain, MITRE ATT&CK, and how raw feeds actually turn into a hunt.

```
$ read section_01 --start
```

WHAT'S INSIDE

SECTION	TOPIC
1 – 3	What threat intel is, IOCs vs IOAs, and the Pyramid of Pain
4 – 6	MITRE ATT&CK, intel sources/feeds, and the intelligence cycle
7 – 9	Enrichment/hunting, a worked IOC-to-hunt example, and reference

How to use this guide: read start to finish for the full picture, or jump to Section 3 if you just need the Pyramid of Pain explained. Every diagram is numbered and referenced directly in the surrounding text.

Table of Contents

1. What Threat Intelligence Actually Is	3
2. IOCs vs IOAs	4
3. The Pyramid of Pain	5
4. MITRE ATT&CK as a Framework	6
5. Threat Intelligence Sources & Feeds	7
6. The Intelligence Cycle	8
7. Applying Intel: Enrichment & Hunting	9
8. Worked Example: From IOC to Hunt	10
9. Quick Reference & Glossary	11

This guide is designed to be read section by section, with diagrams positioned next to the concepts they illustrate.

What Threat Intelligence Actually Is

1.1 NOT JUST A LIST OF BAD IPS

Threat intelligence is evidence-based knowledge about existing or emerging threats – adversary capabilities, infrastructure, intent, and behavior – that's been processed and analyzed specifically to inform security decisions. A raw list of malicious IP addresses is **threat data**; it only becomes **threat intelligence** once it's been given context: who's using this IP, for what campaign, targeting whom, and what that means for your specific environment.

Data, information, and intelligence are not the same thing. Raw data (a log entry, a file hash) becomes information once organized and given basic context (this hash matches a known malware family). It becomes intelligence only once analyzed enough to support an actual decision (this malware family targets our industry, via this delivery method – here's what to watch for). Most of this guide is about that last transformation.

1.2 THE THREE TRADITIONAL TIERS

TIER	AUDIENCE	FOCUS
Strategic	Executives, leadership	High-level trends, risk to the business, threat landscape shifts – rarely technical
Operational	SOC managers, IR leads	Specific campaigns, adversary TTPs, likely near-term targeting
Tactical	Analysts, engineers	Concrete IOCs (Section 2), detection signatures, immediately actionable data

1.3 WHERE THIS GUIDE FITS

This guide focuses primarily on **tactical** and **operational** intelligence – the layer that directly feeds SIEM correlation rules (see the SIEM & Log Analysis guide), YARA/Sigma rules (see the Malware Analysis Basics guide), and IR playbook triggers (see the Incident Response Playbook Companion guide). Strategic intelligence matters for organizational decision-making, but it's a different discipline from the day-to-day analyst work this guide is built around.

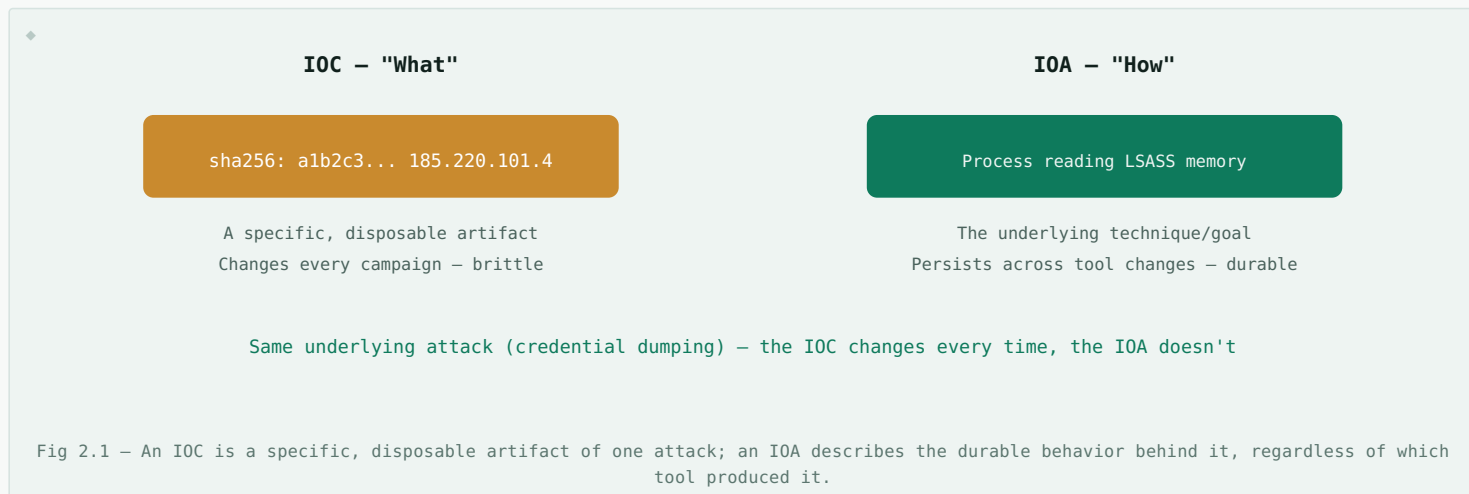
IOCs vs IOAs

2.1 INDICATORS OF COMPROMISE

An **IOC (Indicator of Compromise)** is forensic evidence that a compromise has already occurred or is occurring – a malicious file hash, a known-bad IP address, a specific registry key. IOCs are inherently retrospective and specific: they describe artifacts *of* a particular attack, not the underlying behavior that produced them.

2.2 INDICATORS OF ATTACK

An **IOA (Indicator of Attack)** describes the *behavior* or *intent* behind an action, independent of the specific tools used – "a process is attempting to dump credentials from LSASS memory" is an IOA; the specific hash of the tool doing it is an IOC. IOAs focus on the attacker's goal and technique, not the disposable, easily-changed artifact.



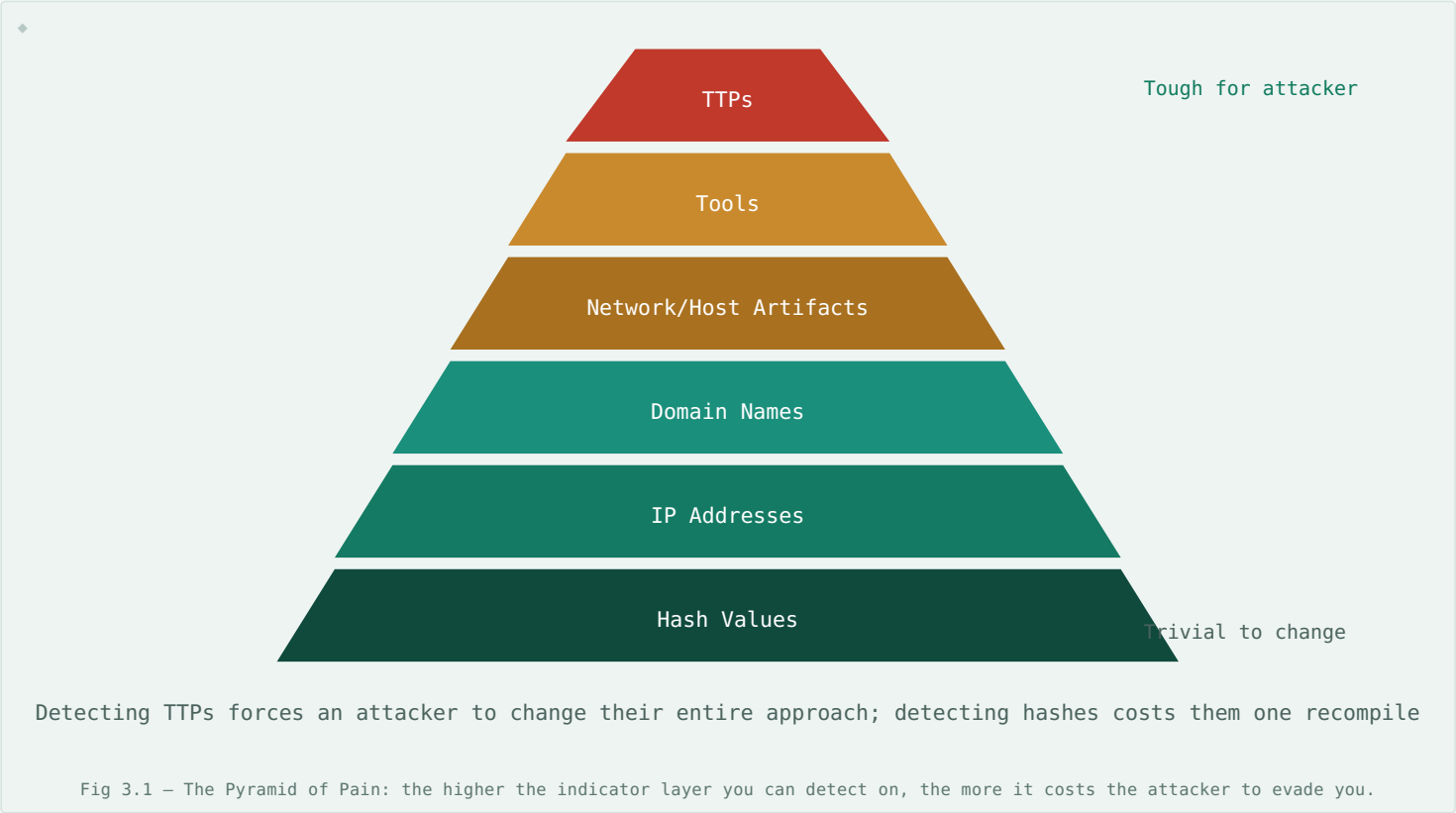
2.3 WHY THIS DISTINCTION DRIVES DETECTION STRATEGY

An attacker can trivially change a file hash by recompiling, or rotate to a new IP address – making pure IOC-based detection a constant game of catch-up. Detecting the underlying *behavior* (IOA) instead – the technique from Section 4's MITRE ATT&CK framework – catches an attacker even when every specific artifact has changed. This exact trade-off is why the SIEM & Log Analysis guide's Section 5.3 recommends building correlation rules around documented attacker behavior, not superficial "unusual" activity – that's an IOA-first design philosophy, expressed in different terms.

The Pyramid of Pain

3.1 NOT ALL INDICATORS ARE EQUALLY VALUABLE

David Bianco's **Pyramid of Pain** ranks indicator types by how much difficulty detecting on them actually causes an attacker – the higher up the pyramid, the more it costs the attacker to change, and the more durable your detection becomes. This is the direct visual expression of Section 2.3's IOC-vs-IOA trade-off, broken into six concrete layers.



3.2 THE SIX LAYERS

LAYER	EXAMPLE	COST TO ATTACKER IF DETECTED
Hash Values	A specific file's SHA-256	Trivial – recompile, one byte change breaks the hash
IP Addresses	185.220.101.4	Easy – rotate to a new host/VPS
Domain Names	evil-c2-domain.com	Simple – register a new domain
Network/Host Artifacts	A distinctive user-agent string, a specific registry key	Annoying – requires reconfiguring tooling
Tools	A specific malware family or framework	Challenging – find or build new tooling entirely
TTPs	Tactics, Techniques & Procedures – the overall approach (Section 4)	Very high – requires fundamentally changing how they operate

This directly explains why YARA and Sigma matter together. A YARA rule (Malware Analysis Basics guide, Section 5) built purely on a hash sits at the pyramid's base – cheap for an attacker to defeat. A Sigma rule (same guide, Section 6) built on behavioral patterns climbs toward the TTP layer – far more durable. Neither is wrong to use, but knowing where each sits on this pyramid sets realistic expectations for how long a given detection will keep working.

MITRE ATT&CK as a Framework

4.1 A SHARED VOCABULARY FOR ATTACKER BEHAVIOR

MITRE ATT&CK is a publicly available, continuously updated knowledge base of real-world adversary tactics and techniques, organized into a matrix – already referenced throughout the Windows Event Log Reference guide (Section 7) and the SIEM & Log Analysis guide (Section 5.3) as the recommended foundation for building genuine, behavior-based detections. This section covers the framework itself, on its own terms.

4.2 TACTICS VS TECHNIQUES VS PROCEDURES

LEVEL	ANSWERS	EXAMPLE
Tactic	"Why?" – the adversary's goal	Credential Access
Technique	"How?" – the general method	T1003 – OS Credential Dumping
Sub-technique	"How, specifically?"	T1003.001 – LSASS Memory
Procedure	"How, in this exact case?"	The specific tool/command a real, named threat actor used

4.3 WHY THE MATRIX STRUCTURE MATTERS

ATT&CK organizes techniques into columns by tactic (Initial Access, Execution, Persistence, Privilege Escalation, and so on), letting an analyst or detection engineer see, at a glance, both what's already covered by existing detections and where genuine gaps remain across the full attack lifecycle – a far more structured way to reason about coverage than an ad-hoc list of individual rules.

4.4 ATT&CK AS A COMMON LANGUAGE, NOT JUST A REFERENCE

Beyond its use as documentation, ATT&CK functions as a shared vocabulary across the entire industry – threat intel reports, vendor tooling, and internal detection rules can all reference the same technique ID (like T1003), meaning intelligence from an external report translates directly and unambiguously into "do we have detection coverage for this specific technique," without needing to reinterpret vendor-specific or inconsistent terminology.

ATT&CK describes behavior, which is exactly why it sits near the top of the Pyramid of Pain. A technique like T1003 (credential dumping) remains valid regardless of which specific tool, hash, or IP an attacker happens to be using this week – it's the framework-level expression of Section 3's TTP layer, the hardest-to-evade indicator type.

Threat Intelligence Sources & Feeds

5.1 WHERE INTELLIGENCE ACTUALLY COMES FROM

SOURCE TYPE	EXAMPLES	CHARACTERISTICS
Open Source (OSINT)	Security vendor blogs, public IOC feeds, Twitter/X researcher posts	Free, broad coverage, variable quality and timeliness
Commercial	Paid threat intel platforms and subscriptions	Curated, often faster, contextualized – costs money
ISAC/ISAO	Industry-specific sharing communities (financial, healthcare, etc.)	Highly relevant to your specific sector, trust-based sharing
Internal	Your own SIEM history, past incidents, IR findings	Uniquely relevant to your actual environment – often undervalued
Government/CERT	National CERT advisories, sector-specific government alerts	Authoritative, sometimes classified/restricted distribution

5.2 FEED FORMATS: STIX & TAXII

STIX (Structured Threat Information eXpression) is a standardized format for representing threat intelligence – indicators, threat actors, campaigns, and the relationships between them – in a machine-readable way. **TAXII (Trusted Automated eXchange of Intelligence Information)** is the transport protocol for actually sharing STIX data between platforms. Together they let intelligence flow automatically between a feed source and a SIEM's ingestion pipeline (SIEM & Log Analysis guide, Section 2), without manual copy-paste of IOC lists.

5.3 NOT ALL SOURCES DESERVE EQUAL TRUST

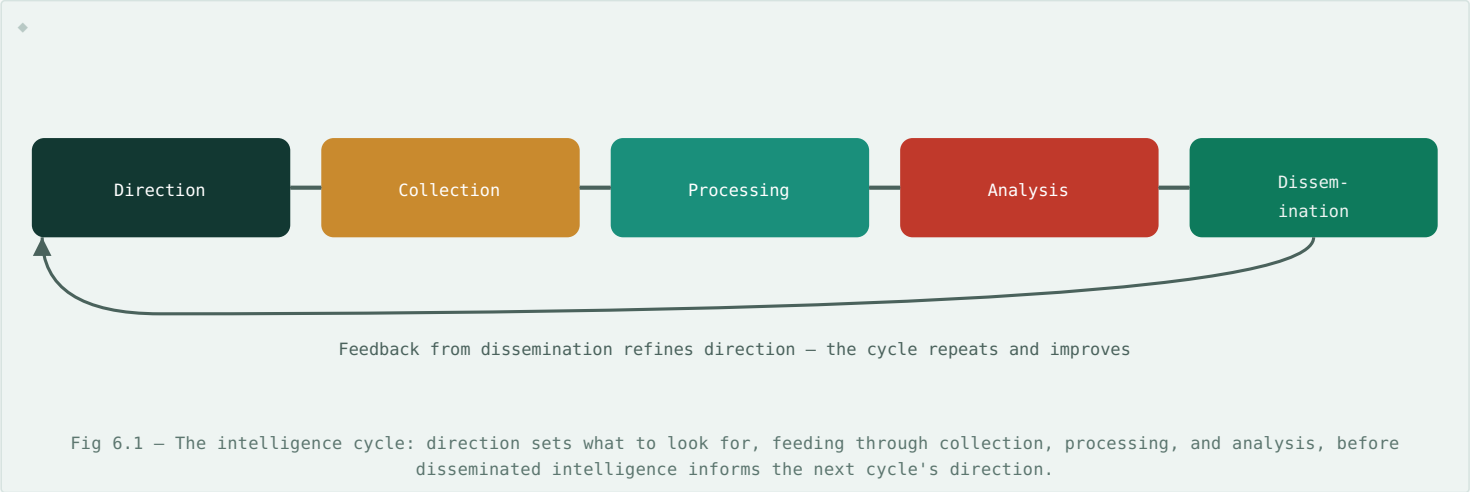
Feed quality varies enormously – some sources produce high false-positive rates, stale indicators long past their relevance, or indicators with no context at all. Applying the same tuning discipline covered in the SIEM & Log Analysis guide's Section 7 to *intelligence sources themselves* – tracking which feeds actually produce actionable, accurate results over time – is just as important as tuning the correlation rules built from them.

Timeliness matters as much as accuracy. A perfectly accurate IOC delivered six months after a campaign ended has limited defensive value – the attacker has almost certainly already rotated infrastructure (Section 3's pyramid explains exactly why). Feed evaluation should weigh how quickly a source delivers intelligence relative to when the underlying activity was actually observed, not just whether the indicators are eventually correct.

The Intelligence Cycle

6.1 A STRUCTURED, REPEATING PROCESS

Threat intelligence work follows a five-stage cycle, similar in spirit to the SIEM pipeline (SIEM & Log Analysis guide, Section 2) and the IR lifecycle (Incident Response Playbook Companion guide, Section 1) – both of which also structure ad-hoc-feeling work into a repeatable process.



6.2 STAGE DETAIL

STAGE	WHAT HAPPENS
Direction	Defining what questions actually need answering – driven by known gaps, recent incidents, or leadership priorities
Collection	Gathering raw data from the sources in Section 5
Processing	Normalizing, deduplicating, and structuring raw collected data into a usable form
Analysis	Applying context and judgment – turning processed data into genuine intelligence (Section 1.1's data-to-intelligence transformation)
Dissemination	Delivering the finished intelligence to whoever needs it – an analyst's dashboard, a correlation rule, an executive briefing

Section 7 covers exactly what dissemination looks like in practice for tactical intelligence – enrichment pipelines and proactive hunting, the two most direct ways finished intelligence gets used day to day.

Applying Intel: Enrichment & Hunting

7.1 ENRICHMENT: INTELLIGENCE MEETING YOUR OWN DATA

Enrichment automatically attaches threat intelligence context to events as they flow through a SIEM – exactly the enrichment stage already introduced in the SIEM & Log Analysis guide's pipeline (Section 2.2), now explained from the intelligence side: when a log event contains an IP or domain, the SIEM checks it against ingested threat feeds (Section 5) and attaches a match, if one exists, before the event ever reaches a correlation rule or an analyst.

7.2 THREAT HUNTING: PROACTIVE, NOT REACTIVE

Where detection (correlation rules, YARA/Sigma) waits for a match against known patterns, **threat hunting** proactively searches historical data for signs of compromise that existing detections might have missed entirely – often starting from a specific hypothesis informed by fresh intelligence ("this newly-published campaign uses this technique – do we see any evidence of it in our environment already?").

7.3 A HUNT HYPOTHESIS, BUILT FROM INTELLIGENCE

A good hunt hypothesis is specific and testable, typically built directly from a Section 4 ATT&CK technique or a Section 1 operational intelligence report: "Given intelligence that threat actor X uses T1003.001 (LSASS memory dumping) via a specific tool, do we have any process creation events (Windows Event Log Reference guide, Section 4) matching that tool's known command-line pattern, anywhere in our retained log history?" This is meaningfully different from a correlation rule – a hunt looks backward through data that already exists, searching for a pattern that wasn't being actively watched for at the time.

A successful hunt often becomes a new standing detection. If a hunt confirms a real gap – a technique with no existing correlation rule coverage – the natural next step is writing one (SIEM & Log Analysis guide, Section 8), so future occurrences of the same pattern are caught automatically going forward rather than requiring another manual hunt. Hunting and detection engineering feed each other continuously.

Worked Example: From IOC to Hunt

A threat intel feed (Section 5) publishes a new report on an active campaign. Walking the full application flow built across this guide:

1. **Raw intelligence arrives (Section 5.2):** a STIX bundle via TAXII feed includes a malicious domain, two file hashes, and a description of the group's typical technique – credential dumping via LSASS access (T1003.001, Section 4.2).
2. **Enrichment (Section 7.1):** the domain and hashes are loaded into the SIEM's threat intel database; any future log event referencing them will now be automatically flagged.
3. **Recognize the Pyramid of Pain trade-off (Section 3):** the domain and hashes are useful but brittle (base of the pyramid) – the report's described *technique* is far more durable, and worth acting on independently of whether this specific campaign's artifacts ever actually appear in your environment.
4. **Build a hunt hypothesis from the technique (Section 7.3):** "Do we have any historical process creation events consistent with LSASS memory access, regardless of whether they match this campaign's specific hashes?"
5. **Execute the hunt:** searching retained Windows Event ID 4688/4663 history (Windows Event Log Reference guide, Sections 4.1 and 4.3) for the relevant access pattern – finds one historical match, three weeks old, that was never flagged by any existing rule.
6. **Escalate as a confirmed incident:** the finding is handed to the IR process (Incident Response Playbook Companion guide) for full identification and containment, since this predates the current intelligence and represents a genuine, previously-undetected compromise.
7. **Close the loop (Section 6.1's feedback):** a new Sigma rule (Malware Analysis Basics guide, Section 6) is written targeting the LSASS access pattern directly – not the campaign's specific, disposable hashes – so the next occurrence, from any actor using the same technique, is caught automatically.

The IOC started the process, but the IOA is what actually closed the gap. Every step in this example traces back to Section 2's core distinction – the specific hashes never appeared anywhere in this environment at all, yet the hunt still surfaced a real, previously-missed compromise, purely by hunting the underlying technique instead of waiting for an exact artifact match.

Quick Reference & Glossary

TERM	DEFINITION
Threat Intelligence	Evidence-based, analyzed knowledge about threats, used to inform security decisions.
IOC	Indicator of Compromise – forensic evidence of an occurred or ongoing compromise.
IOA	Indicator of Attack – behavior or intent, independent of the specific tool used.
Pyramid of Pain	A model ranking indicator types by how costly they are for an attacker to change if detected.
MITRE ATT&CK	A public knowledge base of adversary tactics and techniques, organized into a matrix.
Tactic	An adversary's goal (the "why") within the ATT&CK framework.
Technique	The general method (the "how") used to achieve a tactic.
TTP	Tactics, Techniques & Procedures – an adversary's overall behavioral approach.
STIX	A standardized, machine-readable format for representing threat intelligence.
TAXII	The transport protocol for sharing STIX data between platforms.
Enrichment	Automatically attaching threat intel context to events as they're processed.
Threat Hunting	Proactively searching historical data for compromise that existing detections missed.
Intelligence Cycle	The five-stage process: direction, collection, processing, analysis, dissemination.

End of guide. Every other SOC guide in this series leans on this one implicitly – a correlation rule, a YARA signature, an IR playbook trigger are all, in the end, threat intelligence that's been operationalized. Understanding where indicators sit on the Pyramid of Pain is the single idea from this guide most worth carrying into everything else.